Vulnerability Assessment Report

A comprehensive passive security review of testphp.vulnweb.com identifying configuration-related vulnerabilities and security weaknesses without performing intrusive testing.

SECURITY ASSESSMENT

2026

Executive Summary

Assessment Overview

Passive security assessment conducted on publicly accessible website

Overall Risk Rating: Medium

A thorough passive security assessment was conducted on testphp.vulnweb.com to identify visible security weaknesses without performing any intrusive testing. The evaluation focused on configuration analysis, header inspection, and passive observation techniques.

The assessment identified multiple configuration-related vulnerabilities, primarily involving missing security headers and insecure cookie settings. Whilst no exploitation was performed, these weaknesses substantially increase the website's exposure to common web-based attacks including cross-site scripting, clickjacking, and session hijacking.

Website Assessed

testphp.vulnweb.com

Assessment Type

Passive Read-Only Security Review

Methodology

Header Inspection, Port Scan, Passive Analysis

Scope & Methodology

Assessment Scope

The security review was deliberately limited to non-intrusive techniques to ensure no disruption to the target system whilst maintaining professional ethical standards.

- Public pages only
- No login bypass attempts
- No brute-force attacks
- No exploitation activities
- No denial-of-service testing

Tools & Techniques

Professional security assessment tools were employed to conduct thorough passive analysis of the target website's security posture.

Nmap

Basic port exposure verification

Browser DevTools

HTTP header inspection

Passive Analysis

Security observation techniques

Critical Security Findings

The assessment identified six distinct security vulnerabilities ranging from low to medium severity. Each finding represents a specific configuration weakness that could be exploited by attackers to compromise the website's security or user data.

Missing Content-Security-Policy

Risk Level: Medium

No CSP header implemented, leaving the site vulnerable to cross-site scripting and content injection attacks.

Missing X-Frame-Options Header

Risk Level: Medium

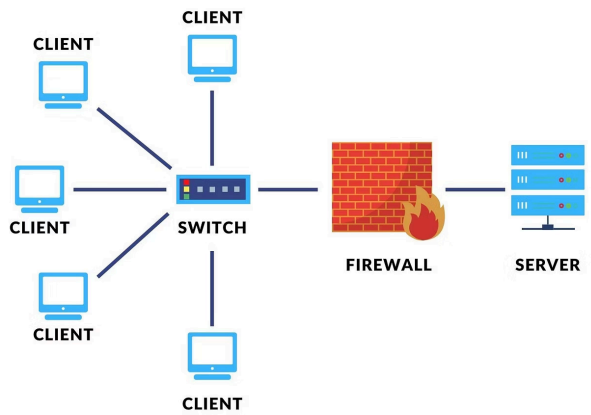
Absence of clickjacking protection allows malicious sites to embed pages in invisible frames.

Missing X-Content-Type-Options

Risk Level: Low

No MIME-type sniffing prevention, potentially allowing disguised malicious files.

Cookie & Server Security Issues



Cookie Security Vulnerability

Risk Level: Medium

Session cookies are configured without the HttpOnly attribute, exposing them to potential theft via JavaScript if cross-site scripting vulnerabilities exist. This creates a significant risk of session hijacking attacks.

Business Impact: Attackers exploiting XSS vulnerabilities could access session cookies and hijack user sessions, gaining unauthorized access to user accounts and sensitive data.

> *"Configure all session cookies with HttpOnly, Secure, and SameSite attributes to prevent unauthorised access."*

Server Information Disclosure

Risk Level: Low

The server reveals technology details and version information in HTTP response headers, providing attackers with reconnaissance data that could be used to identify known vulnerabilities.

Business Impact: Disclosed server information enables attackers to research specific version vulnerabilities and craft targeted attacks against known weaknesses in the identified technology stack.

Recommendation: Disable or mask server version disclosure in web server configuration files immediately.

HTTP Security & Transport Protection

Finding: HTTP Service Accessible Without Forced Redirection

Risk Level: Medium

The website permits access over unencrypted HTTP connections without implementing automatic redirection to HTTPS. This configuration weakness exposes transmitted data to interception, modification, and man-in-the-middle attacks during transit.

Current State

Unencrypted HTTP accessible, data vulnerable in transit

Implement HTTPS

Force secure redirection for all connections

Secure State

HSTS enabled, all traffic encrypted

Critical Recommendation: Implement HTTPS redirection immediately and enable Strict-Transport-Security (HSTS) headers to ensure all connections use encrypted transport protocols.

Port Exposure Analysis

Open Ports Discovered

A basic port exposure check was conducted using Nmap to identify publicly accessible network services. The scan revealed standard web service ports without unnecessary high-risk services.

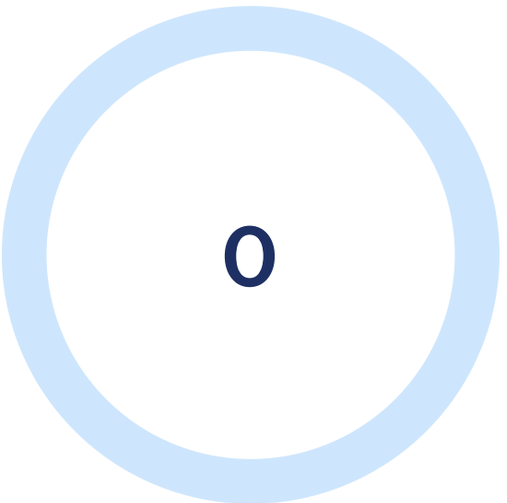
Port	Service	Observation
80	HTTP	Publicly accessible
443	HTTPS	Secure service available

No unnecessary high-risk services were observed during the basic scanning process, indicating appropriate network service management.

Security Observation: Whilst the open port configuration is standard for web services, the lack of forced HTTPS redirection on port 80 remains a concern requiring immediate attention.

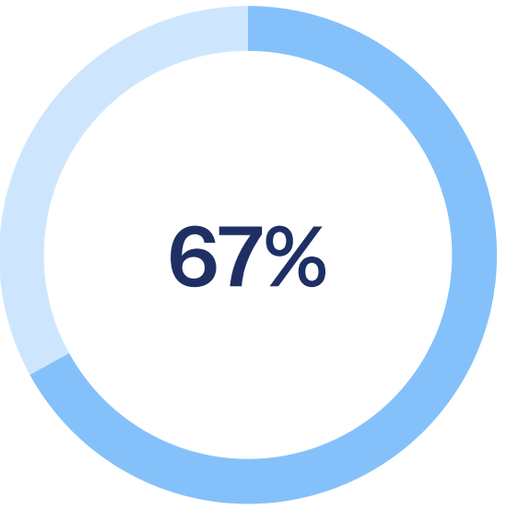
Risk Summary & Security Posture

The comprehensive assessment identified a total of six security vulnerabilities across multiple categories. The risk distribution indicates moderate security concerns that require prompt attention to improve the overall security posture.



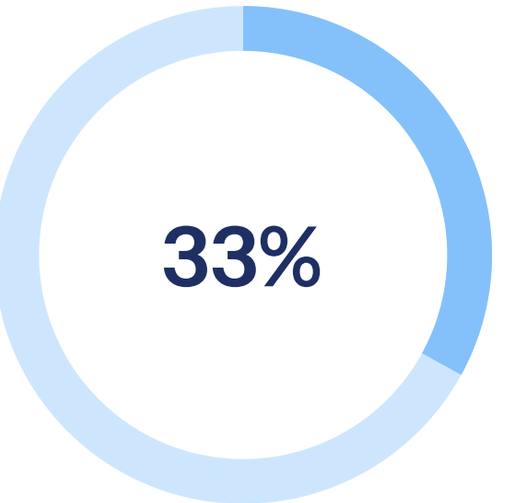
High Risk Issues

No critical vulnerabilities requiring immediate action



Medium Risk Issues

Four configuration weaknesses needing attention



Low Risk Issues

Two minor security observations identified

Overall Security Posture

Moderate Risk Due to Configuration Weaknesses

Whilst no high-severity vulnerabilities were identified, the cumulative effect of multiple medium-risk issues creates a notable attack surface that should be addressed through standard security hardening practices.

Conclusion & Next Steps

Assessment Conclusion

The passive security assessment identified several common web security misconfigurations, primarily related to missing HTTP security headers and inadequate cookie protection settings. Although no active exploitation was performed, these weaknesses substantially increase the attack surface and warrant immediate remediation.

Implementing the recommended fixes will significantly improve the website's resilience against common web-based attacks including cross-site scripting, clickjacking, session hijacking, and man-in-the-middle attacks. The configuration changes are straightforward to implement and align with industry best practices.

Recommended Actions

01

Implement Security Headers

Add CSP, X-Frame-Options, and X-Content-Type-Options

02

Secure Cookie Configuration

Enable HttpOnly, Secure, and SameSite attributes

03

Force HTTPS & Enable HSTS

Implement automatic redirection and transport security

04

Mask Server Information

Disable version disclosure in configuration

Disclaimer: This assessment was conducted using passive, non-intrusive techniques on publicly accessible components only. No exploitation or harmful testing was performed. All findings represent configuration observations that should be verified and addressed according to your organisation's security policies and procedures.